

****February 20, 2025****

****Sanction for Violation of GDPR****

The National Authority for the Supervision of Personal Data Processing completed, in January 2025, an investigation into the operator Medstar S.R.L. and found violations of the provisions of Articles 32, 33, and 34 of Regulation (EU) 2016/679 (GDPR). As such, the operator was sanctioned with:

- a fine of 9,946.2 Lei (equivalent to the amount of 2,000 Euros) for violating the provisions of Article 32 of Regulation (EU) 2016/679.
- a warning for violating the provisions of Articles 33 and 34 of Regulation (EU) 2016/679.

The investigation was initiated following a complaint from a data subject, who reported that the operator where they underwent medical tests, the Medstar clinic, disclosed their personal data and that of another data subject.

During the investigation, it was found that the operator disclosed health data of the complainant to another person (patient), and the health data of another patient was erroneously and unsecuredly transmitted to the complainant via electronic mail.

Thus, this situation led to the unauthorized disclosure of personal and sensitive data belonging to several data subjects, such as: name, surname, personal identification number, age, sex, locality, mobile phone number, email addresses, medical data from the patient's history, type of tests performed, name of the doctor who made the recommendation and their specialty, name of the doctor who performed the tests and their specialty, test results, medical recommendation, name of the payer, prescribed treatment.

It was also found that the operator did not adopt sufficient technical and organizational security measures in accordance with Article 32 of the GDPR, adapted to the nature of the personal data that was processed, which led to the unauthorized disclosure of personal data of certain data subjects.

As such, the operator Medstar S.R.L. was sanctioned with a fine for violating the provisions of Article 32 of Regulation (EU) 2016/679.

At the same time, since the operator did not notify the data breach to the National Authority for the Supervision of Personal Data Processing nor did it inform the data subjects about the unauthorized disclosure of their personal data, it received two warnings for violating the provisions of Articles 33 and 34 of Regulation (EU) 2016/679.

Additionally, the operator was ordered to implement the following corrective measures:

- to ensure compliance with the GDPR for personal data processing operations by implementing appropriate technical and organizational security measures specific to the processing and identified risks throughout the data processing cycle, particularly regarding the verification of the accuracy of processed personal data, establishing appropriate rules related to the management of files that may be transmitted using electronic communication means (remotely), training individuals who process data under the authority of the operator, regularly verifying compliance with the instructions given to them, and automating certain processes to reduce the risks of illegal or unauthorized processing of personal data;
- to ensure compliance with the GDPR for personal data processing operations by adopting necessary internal measures for the rapid detection, management, and reporting of personal data security breach situations, whether or not they require notification to the supervisory authority and/or the data subjects, as well as appropriate and regular training of individuals who process data under the authority of the operator in this context;
- to inform the individuals whose personal data was disclosed about the data security breach by providing them with the information specified in Article 34 of the GDPR;
- to ensure compliance with the GDPR for personal data processing operations by requesting the individuals whose data was disclosed (data subjects) not to use and to delete the personal data of third parties that were disclosed unauthorizedly.

****Legal and Communication Department****

****N.A.S.P.D.C.P****